



Esercizio Epcode Google Hacking

ESERCIZIO EPICODE WEEK 10 DAY 2 A CURA DI FABIO RENNA

Indice

Executive Summary.....	2
Introduzione.....	2
Obiettivo.....	3
Proof of Concept.....	4-8
Conclusione.....	9

Executive Summary

Durante l'analisi del sito *juice-shop.herokuapp.com* tramite tecniche di Google Hacking sono state identificate diverse vulnerabilità critiche, tra cui l'esposizione pubblica di directory interne contenenti file di log sensibili, informazioni sul sistema, tracciamenti degli utenti e persino payload di attacchi reali (SQL Injection, XSS e Command Injection).

L'indagine ha evidenziato un grave caso di **Sensitive Data Exposure** e **Security Misconfiguration**, che rendono possibile a chiunque scaricare e analizzare file di log interni con informazioni dettagliate sulle attività del server. Questo tipo di esposizione amplifica notevolmente la superficie d'attacco e permette a potenziali aggressori di studiare pattern, endpoint e vulnerabilità già sfruttate da altri attaccanti.

Sono state definite specifiche misure di mitigazione necessarie per proteggere i dati esposti e correggere le configurazioni insicure.

Introduzione

OWASP Juice Shop è un'applicazione deliberatamente vulnerabile, utilizzata per scopi didattici. Lo scopo dell'esercitazione è applicare tecniche base di **Google Hacking** per individuare pagine, file ed endpoint indicizzati in maniera involontaria, simulando un'attività di recon tipica del penetration testing.

Le tracce fornite da Epicode richiedono di:

1. utilizzare comandi Google Dorks;
2. analizzare i risultati ottenuti;
3. identificare eventuali informazioni sensibili;
4. proporre misure di sicurezza adeguate.

Obiettivo

Gli obiettivi principali di questa analisi sono:

1. Raccolta informazioni tramite Google Hacking

Utilizzando i comandi site:, inurl:, intext:, filetype:.

2. Identificazione di informazioni sensibili

Valutazione della presenza di directory, file, endpoint o dati esposti involontariamente.

3. Raccolta di prove (Proof of Concept)

Analisi diretta delle informazioni esposte (log, file JSON, endpoint, payload malevoli).

4. Valutazione del rischio

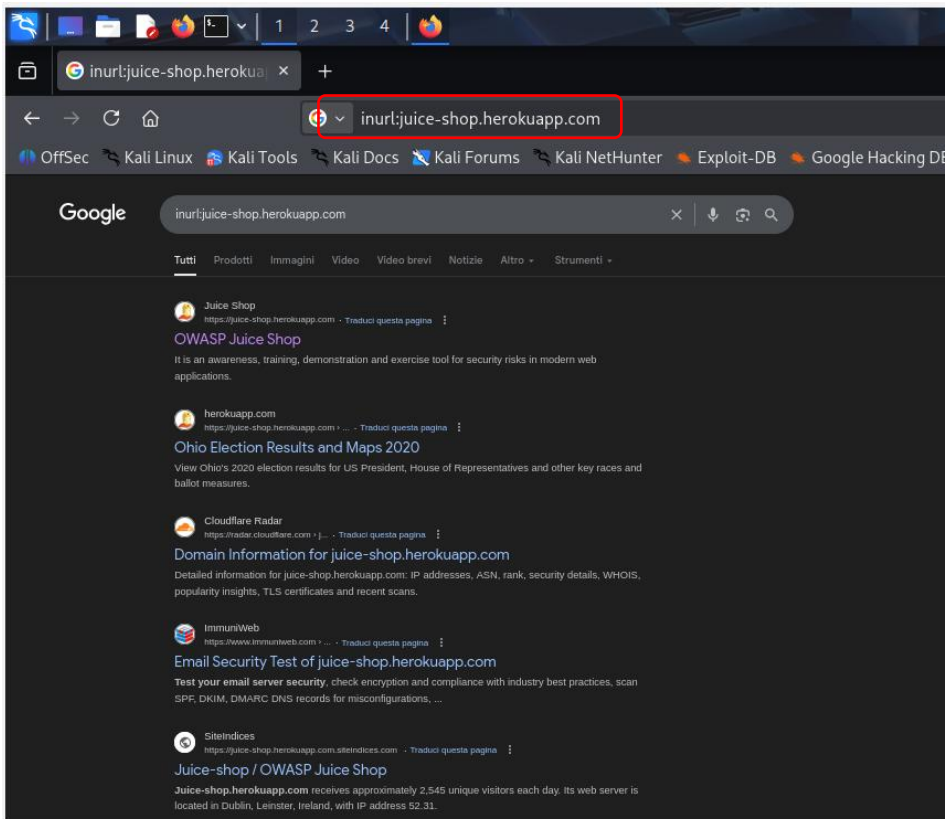
Classificazione delle vulnerabilità secondo categorie OWASP.

5. Definizione delle misure correttive

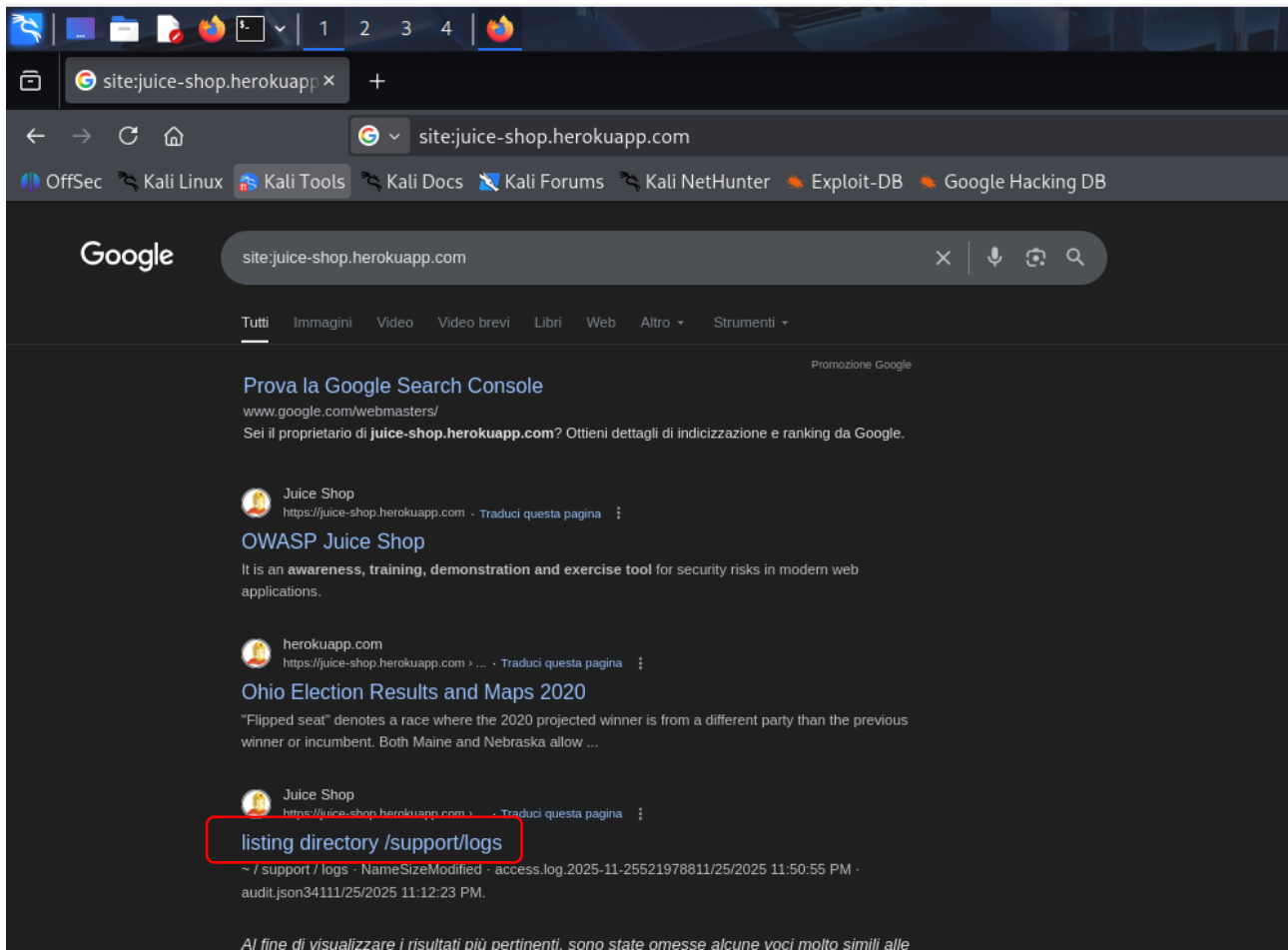
Indicazione delle azioni necessarie a proteggere il sito e gli utenti.

Proof of Concept

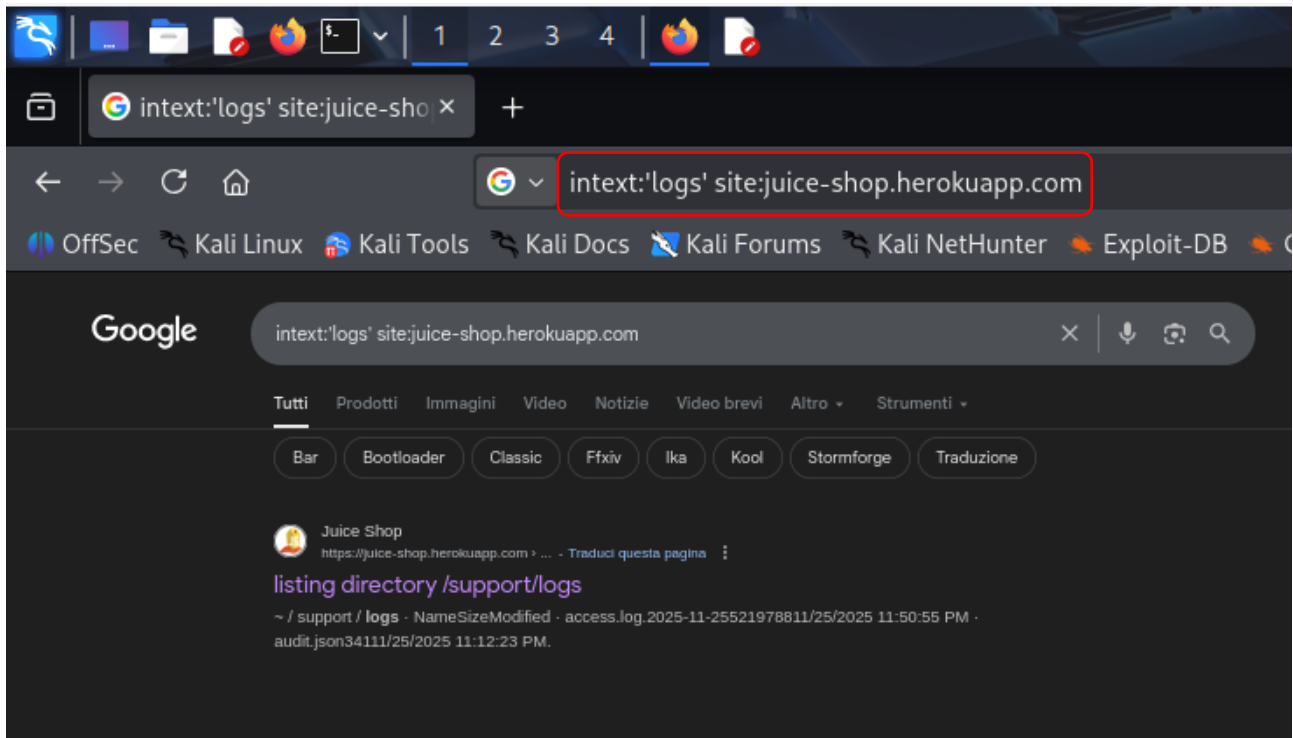
Utilizzando il comando `inurl:juice-shop.herokuapp.com`, Google restituisce diverse risorse indicizzate del dominio, includendo pagine principali, analisi DNS, informazioni sul certificato SSL e servizi esterni. Questo permette un primo mapping del sito e conferma la presenza di metadati non necessari esposti pubblicamente.



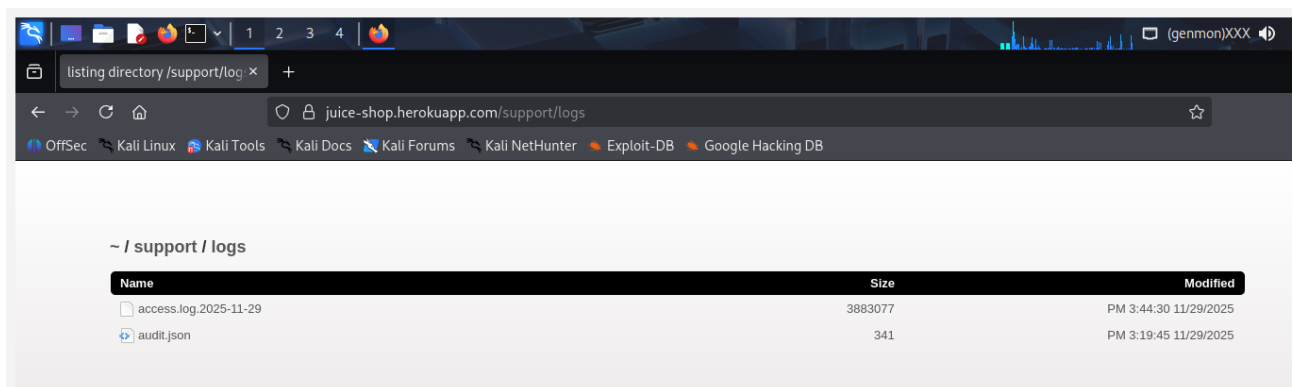
Il comando `site:juice-shop.herokuapp.com` mostra tutte le pagine indicizzate da Google. Tra queste compare immediatamente una directory sospetta: `/support/logs`. Questo suggerisce la possibile presenza di file sensibili accessibili senza autenticazione.



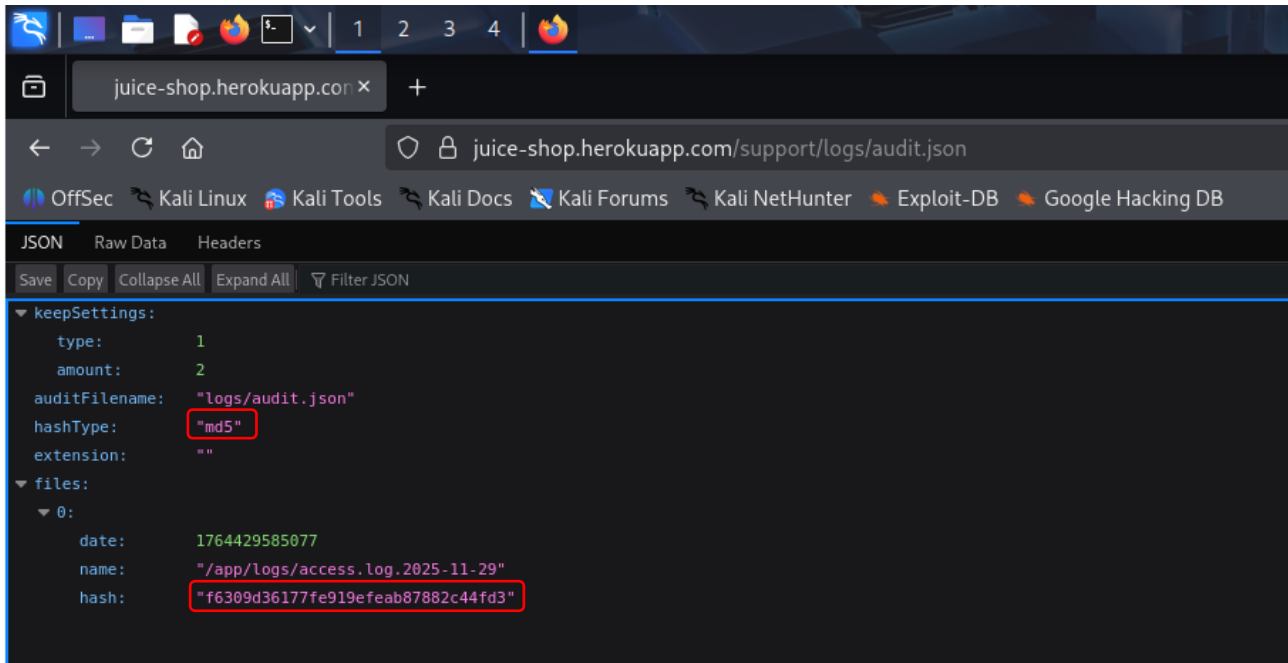
Con **intext:'logs' site:juice-shop.herokuapp.com**, Google restituisce direttamente la pagina di listing della cartella **/support/logs**. La presenza di file log all'interno di una directory accessibile via browser è un forte indicatore di Security Misconfiguration.



Accedendo alla directory **/support/logs**, è possibile visualizzare e scaricare liberamente file sensibili come **access.log** e **audit.json**. Questo rappresenta una vulnerabilità critica: i log del server non dovrebbero mai essere esposti pubblicamente, poiché possono contenere dati personali e informazioni strutturali dell'applicazione.



L'apertura del file **audit.json** rivela dettagli interni del sistema, come i percorsi dei log, l'algoritmo di hashing utilizzato (MD5, obsoleto) e la struttura interna delle configurazioni. Questo tipo di Information Disclosure aumenta notevolmente il rischio di attacchi mirati.



Il file **access.log** contiene informazioni estremamente sensibili: indirizzi IP reali, user-agent completi, endpoint API, parametri GET e POST. Questi dati permettono a un attaccante di comprendere la struttura del sito, identificare tecnologie utilizzate e potenziali punti di ingresso.

Analizzando il proseguimento del log, emergono payload malevoli di attacchi reali: SQL Injection (**updatexml()**), tentativi di Remote Command Execution (**cat /etc/passwd**), e vettori XSS (**onerror=alert(document.domain)**). La presenza di questi dati indica che la piattaforma è attivamente bersagliata e che i log esposti consentono a un attaccante di studiare gli exploit già tentati.

Conclusione

L'analisi svolta ha evidenziato una grave esposizione di informazioni sensibili dovuta a una configurazione non sicura del sito, in particolare alla presenza della directory **/support/logs** accessibile pubblicamente. I file contenuti al suo interno rivelano dati tecnici, percorsi del server, attività degli utenti e persino i payload completi di attacchi reali, facilitando in modo significativo il lavoro di un potenziale aggressore.

Per migliorare la sicurezza, è essenziale rimuovere l'accesso pubblico ai file di log, spostarli fuori **dalla root** del sito e proteggerli con permessi adeguati. Contemporaneamente andrebbero introdotte misure come un **Web Application Firewall**, una migliore validazione dell'input e una configurazione più restrittiva degli endpoint e dei messaggi di errore.

Intervenendo su questi aspetti è possibile ridurre sensibilmente la superficie d'attacco e prevenire ulteriori esposizioni di informazioni critiche, garantendo una gestione più sicura dei dati e un funzionamento più resiliente dell'applicazione.

Venezia, 24/11/2025

Fabio Renna